

Fundamentals of Information Systems Security

Chapter 1 Quiz: Introduction to Information Security

Name: _____

Date: _____

Total Points: 100

Time Allowed: 30 Minutes

Instructions

- This quiz contains **20 questions** covering Chapter 1
- Answer all questions to the best of your ability
- Multiple choice questions have only one correct answer
- True/False questions should be marked T or F
- Short answer questions require concise, accurate responses

Section A: Multiple Choice (40 points)

1. (4 points) What are the three core principles of the CIA Triad?
 - A. Confidentiality, Integrity, Availability
 - B. Confidentiality, Identity, Access
 - C. Control, Integrity, Accountability
 - D. Compliance, Identity, Authentication
2. (4 points) Which of the following is NOT one of the seven IT infrastructure domains?
 - A. User Domain
 - B. Workstation Domain
 - C. Application Domain
 - D. Business Domain
3. (4 points) What is the primary purpose of a security policy?
 - A. To generate revenue
 - B. To reduce risk and guide security decisions
 - C. To limit employee access to the internet
 - D. To comply with international law
4. (4 points) Which type of attack is characterized by exploiting human psychology rather than technical vulnerabilities?
 - A. Malware attack
 - B. Denial-of-Service attack
 - C. Social engineering attack

- D. Brute-force attack
5. (4 points) What percentage of security incidents are attributed to internal attacks according to FBI statistics?
- A. 20-30%
 - B. 30-40%
 - C. 60-80%
 - D. 80-90%
6. (4 points) Which of the following is an example of a physical security control?
- A. Firewall
 - B. Encryption
 - C. Biometric scanner
 - D. Password policy
7. (4 points) The process of verifying a user's claimed identity is called:
- A. Identification
 - B. Authentication
 - C. Authorization
 - D. Accountability
8. (4 points) What is the correct hierarchy of the security policy framework from highest to lowest level?
- A. Procedures → Policy → Standards → Guidelines
 - B. Policy → Standards → Procedures → Guidelines
 - C. Standards → Policy → Guidelines → Procedures
 - D. Guidelines → Procedures → Policy → Standards
9. (4 points) Which attack type sends multiple SYN packets with spoofed IP addresses to exhaust server resources?
- A. Smurf attack
 - B. Teardrop attack
 - C. SYN Flood attack
 - D. DNS attack
10. (4 points) The Security Systems Development Life Cycle (SecSDLC) includes which of the following phases?
- A. Investigation, Analysis, Design, Implementation, Maintenance
 - B. Planning, Budgeting, Testing, Deployment, Review
 - C. Research, Development, Testing, Launch, Support
 - D. Identify, Assess, Mitigate, Monitor, Recover

Section B: True/False (20 points)

11. (2 points) The human factor is considered the weakest link in information security.
 - A. True
 - B. False
12. (2 points) A law is a legislative piece voted on by the people for the people.
 - A. True
 - B. False
13. (2 points) The LAN-to-WAN Domain deals with internal network hardware only.
 - A. True
 - B. False
14. (2 points) Structured attacks are performed by inexperienced attackers using pre-written tools.
 - A. True
 - B. False
15. (2 points) Information security decisions should involve three distinct groups: security professionals, IT professionals, and business management.
 - A. True
 - B. False
16. (2 points) Physical sabotage is considered a digital threat.
 - A. True
 - B. False
17. (2 points) The Acceptable Use Policy (AUP) defines proper system and resource usage.
 - A. True
 - B. False
18. (2 points) Internal attacks account for only 10-20% of all security incidents.
 - A. True
 - B. False
19. (2 points) Shoulder surfing is a type of physical security threat.
 - A. True
 - B. False
20. (2 points) The six P's framework includes Planning, Policy, Programs, Protection, People, and Project Management.
 - A. True
 - B. False

Section C: Short Answer (40 points)

21. (10 points) Explain the difference between a structured attack and an unstructured attack. Provide an example of each.
22. (10 points) List and briefly describe the three communities of interest involved in information security decision-making.
23. (10 points) Describe the five-step problem-solving methodology for security issues.
24. (10 points) What are the four levels of data classification discussed in Chapter 1? Briefly describe each.